

## PASTA worksheet

| Stages                                     | Sneaker company                                                                                                                                                                                                                                                                                                                     |
|--------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| I. Define business and security objectives | <ul style="list-style-type: none"><li>• Develop a secure mobile application that allows users to buy and sell sneakers.</li><li>• Protect customer data and maintain user privacy throughout the application.</li><li>• Provide secure messaging, multiple payment options, and a fast, reliable checkout process.</li></ul>        |
| II. Define the technical scope             | I would prioritize evaluating the <b>API</b> because it handles communication between the mobile application, users, and the database. If the API is not properly secured, attackers could gain unauthorized access to sensitive customer information or manipulate application data, making it one of the highest-risk components. |
| III. Decompose application                 | <a href="#">Sample data flow diagram</a><br>User submits login credentials through the mobile app. The API validates the request, communicates with the SQL database, and securely returns the requested information using encrypted connections.                                                                                   |
| IV. Threat analysis                        | <ul style="list-style-type: none"><li>• <b>SQL Injection</b> attacks targeting the database.</li><li>• <b>Phishing or credential theft</b> leading to unauthorized account access.</li></ul>                                                                                                                                        |
| V. Vulnerability analysis                  | <ul style="list-style-type: none"><li>• Weak input validation that could allow SQL injection attacks.</li><li>• Weak authentication or poor password management that could allow unauthorized access.</li></ul>                                                                                                                     |
| VI. Attack modeling                        | <a href="#">Sample attack tree diagram</a>                                                                                                                                                                                                                                                                                          |
| VII. Risk analysis and impact              | <ul style="list-style-type: none"><li>• Implement <b>Multi-Factor Authentication (MFA)</b> for user accounts.</li></ul>                                                                                                                                                                                                             |

|  |                                                                                                                                                                                                                                                                                                                                    |
|--|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <ul style="list-style-type: none"><li>● Apply the <b>Principle of Least Privilege (PoLP)</b> to limit user access.</li><li>● Encrypt sensitive data using <b>AES</b> and secure communications using <b>RSA/TLS</b>.</li><li>● Perform regular <b>security audits</b>, vulnerability assessments, and system monitoring.</li></ul> |
|--|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

---